

Website Vulnerability Scanner Report (Light)



Unlock the full capabilities of this scanner



See what the DEEP scanner can do

Perform in-depth website scanning and discover high risk vulnerabilities.

Testing areas	Light scan	Deep scan
Website fingerprinting	✓	✓
Version-based vulnerability detection	✓	✓
Common configuration issues	✓	✓
SQL injection	—	✓
Cross-Site Scripting	—	✓
Local/Remote File Inclusion	—	✓
Remote command execution	—	✓
Discovery of sensitive files	—	✓

✓ <https://submit.thelodgegroup.id/>

! The Light Website Scanner didn't check for critical issues like SQLi, XSS, Command Injection, XXE, etc.
[Upgrade to run Deep scans with 40+ tests](#) and detect more vulnerabilities.

Summary

Overall risk level:

High

Risk ratings:

Critical:	0
High:	1
Medium:	0
Low:	3
Info:	2

Scan information:

Start time:	Aug 21, 2026 / 19:23:07 UTC+03
Finish time:	Aug 21, 2026 / 19:23:47 UTC+03
Scan duration:	40 sec
Tests performed:	40
Scan status:	Finished

Findings



Vulnerabilities found for next.js 14.2.35

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2026-44578	8.6	0.38872	0.98471	Next.js is a React framework for building full-stack web applications. From 13.4.13 to before 15.5.16 and 16.2.5, self-hosted applications using the built-in Node.js server can be vulnerable to server-side request forgery through crafted WebSocket upgrade requests. An attacker can cause the server to proxy requests to arbitrary internal or external destinations, which may expose internal services or cloud metadata endpoints. Vercel-hosted deployments are not affected. This vulnerability is fixed in 15.5.16 and 16.2.5.

CVE-2026-64649	8.3	0.00536	0.43045	Next.js is a React framework for building full-stack web applications. In versions 14.1.1 through 15.5.20 and 16.0.0 through 16.2.10, when a Server Action forwards or redirects a request, an attacker can cause the server to send that outbound request to a malicious host (Server-Side Request Forgery). This requires the attacker's request to control Host-associated headers. In some configurations, it's also possible to obtain internal values that weaken middleware/proxy authorization. Applications that use Server Actions are affected when the incoming host header is not fixed to a trusted value. This typically occurs on custom servers, or on deployments not behind a proxy that pins the host. Managed hosting pins the host upstream and is not affected; next start and standalone output do the same from version 14.2 onward. This issue has been fixed in versions 15.5.21 and 16.2.11.
CVE-2026-64645	8.3	0.00782	0.5326	Next.js is a React framework for building full-stack web applications. In versions 12.0.0 through 15.5.20 and 16.0.0 through 16.2.10, a <code>rewrites()</code> or <code>redirects()</code> rule that builds its external destination hostname from request-controlled input can be pointed at an arbitrary hostname, regardless of the rule's hostname suffix. For a rewrite, Next.js proxies the request to that arbitrary host and serves the response from the application's origin, leading to Server-Side Request forgery. A <code>redirects()</code> rule configured this way is vulnerable to an Open Redirect. This issue has been fixed in versions 15.5.21 and 16.2.11.
CVE-2026-64641	8.2	0.00599	0.46165	Next.js is a React framework for building full-stack web applications. In versions 13.0.0 through 15.5.20 and 16.0.0 through 16.2.10, crafted requests targeting Next.js applications using App Router with at least one Server Action can lead to excessive CPU usage blocking processing of further requests in the same process. This issue has been fixed in versions 15.5.21 and 16.2.11.
CVE-2026-44573	7.5	0.0062	0.4715	Next.js is a React framework for building full-stack web applications. From 12.2.0 to before 15.5.16 and 16.2.5, Applications using the Pages Router with <code>i18n</code> configured and middleware/proxy-based authorization can allow unauthorized access to protected page data through locale-less <code>/_next/data/<buildId>/<page>.json</code> requests. In affected configurations, middleware does not run for the unprefixed data route, allowing an attacker to retrieve SSR JSON for protected pages without passing the intended authorization checks. This vulnerability is fixed in 15.5.16 and 16.2.5.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.38872

EPSS percentile : 0.98471

CISA KEV: False

CVE : [CVE-2026-44578](#), [CVE-2026-64649](#), [CVE-2026-64645](#), [CVE-2026-64641](#), [CVE-2026-44573](#)

CVSS V3 : 8.6

CWE : [CWE-1035](#)

🚩 **Unsafe security header: Content-Security-Policy**

port 443/tcp

CONFIRMED

URL	Evidence
https://submit.thelodgegroup.id/	Response headers include the HTTP Content-Security-Policy security header with the following security issues: <pre>script-src: 'self' can be problematic if you host JSONP, Angular or user uploaded files. script-src: https: URI in script-src allows the execution of unsafe scripts. script-src: 'unsafe-inline' allows the execution of unsafe in-page scripts and event handlers.</pre> Request / Response

▼ Details

Risk description:

For example, if the `unsafe-inline` directive is present in the CSP header, the execution of inline scripts and event handlers is allowed. This can be exploited by an attacker to execute arbitrary JavaScript code in the context of the vulnerable application.

Recommendation:

Remove the unsafe values from the directives, adopt nonces or hashes for safer inclusion of inline scripts if they are needed, and explicitly define the sources from which scripts, styles, images or other resources can be loaded.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-1021](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Robots.txt file found

port 443/tcp

CONFIRMED

URL<https://submit.thelodgegroup.id/robots.txt>

▼ Details

Risk description:

There is no particular security risk in having a robots.txt file. However, it's important to note that adding endpoints in it should not be considered a security measure, as this file can be directly accessed and read by anyone.

Recommendation:

We recommend you to manually review the entries from robots.txt and remove the ones which lead to sensitive locations in the website (ex. administration panels, configuration files, etc).

References:

<https://www.theregister.co.uk/2015/05/19/robotstxt/>

Classification:

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

 Server software and technology found

port 443/tcp

UNCONFIRMED ⓘ

Software / Version	Category
 HTTP/3	Miscellaneous
 Lucide	Font scripts
 Next.js 14.2.35	JavaScript frameworks, Web frameworks, Web servers, Static site generator
 Next.js App Router	JavaScript frameworks, Web servers
 React	JavaScript frameworks
 PWA	Miscellaneous
 Webpack	Miscellaneous
 Priority Hints	Performance
 Cloudflare	CDN
 HSTS	Security

▼ Details

Risk description:

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Security.txt file is missing**CONFIRMED**

port 443/tcp

URL

Missing: <https://submit.thelodgegroup.id/.well-known/security.txt>

Details**Risk description:**

There is no particular risk in not having a security.txt file for your server. However, this file is important because it offers a designated channel for reporting vulnerabilities and security issues.

Recommendation:

We recommend you to implement the security.txt file according to the standard, in order to allow researchers or users report any security issues they find, improving the defensive mechanisms of your server.

References:

<https://securitytxt.org/>

Classification:

CWE : [CWE-1188](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 HTTP OPTIONS enabled**CONFIRMED**

port 443/tcp

URL	Method	Summary
https://submit.thelodgegroup.id/	OPTIONS	We did a HTTP OPTIONS request. The server responded with a 405 status code and the header: <code>Allow: GET, HEAD</code> Request / Response

Details**Risk description:**

The only risk this might present nowadays is revealing debug HTTP methods that can be used on the server. This can present a danger if any of those methods can lead to sensitive information, like authentication information, secret keys.

Recommendation:

We recommend that you check for unused HTTP methods or even better, disable the OPTIONS method. This can be done using your webserver configuration.

References:

<https://techcommunity.microsoft.com/t5/iis-support-blog/http-options-and-default-page-vulnerabilities/ba-p/1504845>

<https://docs.nginx.com/nginx-management-suite/acm/how-to/policies/allowed-http-methods/>

Classification:

CWE : [CWE-16](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Scan coverage information

List of tests performed (40)

Port 443

- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for robots.txt file
- ✓ Scanned for website technologies
- ✓ Scanned for unsafe HTTP header Content Security Policy
- ✓ Scanned for enabled HTTP OPTIONS method
- ✓ Scanned for absence of the security.txt file
- ✓ Scanned for client access policies
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Scanned for secure communication
- ✓ Scanned for directory listing
- ✓ Scanned for passwords submitted unencrypted
- ✓ Scanned for error messages
- ✓ Scanned for debug messages
- ✓ Scanned for code comments
- ✓ Scanned for missing HTTP header - Strict-Transport-Security
- ✓ Scanned for missing HTTP header - Content Security Policy
- ✓ Scanned for missing HTTP header - X-Content-Type-Options
- ✓ Scanned for missing HTTP header - Referrer
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for domain too loose set for cookies
- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion
- ✓ Scanned for internal error code
- ✓ Scanned for HttpOnly flag of cookie
- ✓ Scanned for Secure flag of cookie
- ✓ Scanned for login interfaces
- ✓ Scanned for secure password submission
- ✓ Scanned for sensitive data
- ✓ Scanned for OpenAPI files
- ✓ Scanned for file upload
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response
- ✓ Scanned for Path Disclosure
- ✓ Scanned for Session Token in URL
- ✓ Scanned for API endpoints
- ✓ Scanned for emails
- ✓ Scanned for missing HTTP header - Rate Limit
- ✓ Scanned for PEM-encoded private key material
- ✓ Scanned for partial PEM-encoded private key material

Scan parameters

target:	https://submit.thelodgegroup.id/
scan_type:	Light
authentication:	False

Scan stats

Unique Injection Points Detected:	14
URLs spidered:	13
Total number of HTTP requests:	26
Average time until a response was received:	228ms